

CVEs más relevantes de la semana

Del 22/08/2026 al 29/08/2026

Porque el primer paso para defender es conocer las amenazas.



CVE-2026-16286

Descripción: Unrestricted upload of file with dangerous type vulnerability in TRtek Technological Products Computer Software Hardware Industry and Trade Limited Company Software Repository Management allows Upload a Web Shell to a Web Server.

This issue affects Software Repository Management: before 2fb4acee.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-434

Tecnología: No especificado

Publicado el: 2026-08-25



CVE-2026-79787

Descripción: Alluxio's S3 REST proxy fails to verify AWS Signature Version 4 signatures in its default configuration, allowing unauthenticated attackers to spoof user identity. Attackers can extract usernames from unsigned Authorization headers and impersonate any user, including service accounts, to read, write, and delete arbitrary data.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-287

Tecnología: No especificado

Publicado el: 2026-08-25



CVE-2026-81702

Descripción: openssl_encrypt before 1.4.9 fails to re-derive and validate fingerprints when loading identities from identity.json, allowing attackers to substitute public keys in identity stores. Attackers can replace legitimate public keys with their own while maintaining the claimed fingerprint, enabling silent key substitution where encryption uses attacker keys and signature verification appears valid.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-345

Tecnología: No especificado

Publicado el: 2026-08-27



CVE-2026-81707

Descripción: openssl_encrypt before 1.4.9 fails to sanitize the email field of imported identity documents, allowing attackers to inject ANSI escape sequences that forge the fingerprint verification line displayed to users. Attackers can deliver a crafted identity bundle through normal contact-exchange flows or keyserver responses to manipulate terminal output and display a fraudulent fingerprint, bypassing...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-20

Tecnología: No especificado

Publicado el: 2026-08-27



CVE-2026-81735

Descripción: startServer.ts in the mcp-http-server package of UI-TARS-desktop defaulted its listen address to '::' when no host was given, so startSseAndStreamableHttpMcpServer bound the Streamable HTTP and SSE MCP transports to every interface, and its authentication middleware was optional: middlewares are applied only when a caller supplies them. The @agent-infra/mcp-server-commands and @agent-infra/mcp-...

CVSS: 10.0 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-306

Tecnología: No especificado

Publicado el: 2026-08-27



CVE-2026-82266

Descripción: Redpanda through 26.2.2 binds the Admin API to 0.0.0.0:9644 with admin_api_require_auth defaulting to false, treating unauthenticated requests as superusers. Attackers can reach port 9644 without credentials to create and delete broker accounts, modify cluster configuration, and disrupt partition replication.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-306

Tecnología: No especificado

Publicado el: 2026-08-28



CVE-2026-82277

Descripción: Argo Rollouts dashboard through 1.10.0 binds to all interfaces and exposes mutating Rollout operations without authentication, authorization, or CSRF protection. Attackers on the same network can invoke PromoteRollout, AbortRollout, RestartRollout, SetRolloutImage, UndoRollout, and RetryRollout operations across all namespaces accessible to the operator's kubeconfig.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-306

Tecnología: No especificado

Publicado el: 2026-08-28



CVE-2026-18527

Descripción: IBM Administration Runtime Expert for i 1R1M0 IBM Application Runtime Expert (ARE) for i could allow a remote attacker to gain elevated privileges, caused by ARE GUI component processing. An unauthenticated attacker can exploit this vulnerability to execute actions under another user's authenticated profile gaining elevated privileges on the IBM i system.

CVSS: 9.9 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-384

Tecnología: No especificado

Publicado el: 2026-08-28



CVE-2026-19286

Descripción: IBM Langflow OSS 1.0.0 through 1.11.1 could allow a remote attacker to execute arbitrary code due to improper enforcement of security restrictions on the A2A public endpoint.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-94

Tecnología: No especificado

Publicado el: 2026-08-28



CVE-2026-19295

Descripción: IBM Langflow OSS 1.0.0 through 1.11.1 allows an authenticated attacker to execute arbitrary operating system commands in the server process by saving a flow with a crafted type field value and triggering a build of a wrapper flow that references it. This allowed privilege escalation from "authenticated flow user" to arbitrary OS-level command execution under the server process identity, bypassi...

CVSS: 9.9 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-95

Tecnología: No especificado

Publicado el: 2026-08-28



CVE-2026-3627

Descripción: IBM Concert 1.0.0 through 2.3.1 is vulnerable to SQL injection. A remote attacker could send specially crafted SQL statements, which could allow the attacker to view, add, modify, or delete information in the back-end database.

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

Tipo: N/A

Tecnología: No especificado

Publicado el: 2026-08-28



CVE-2026-14494

Descripción: The Sigma Forms Pro plugin for WordPress is vulnerable to Remote Code Execution in all versions up to, and including, 1.4.5 via the `handle_form_submission` function. This is due to the plugin dynamically granting the `unfiltered_upload` capability to all users during form submissions and bypassing MIME type validation when `allowed_file_types` is not configured. This makes it possible for unauthenti...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-434

Tecnología: No especificado

Publicado el: 2026-08-29



CVE-2026-82448

Descripción: Shinobi before commit 5a76c74f contains a hardcoded connection key in the child node service that allows unauthenticated attackers to execute arbitrary database queries. Attackers reaching the child node port can present the hardcoded key during WebSocket handshake, then dispatch SQL queries through the onWebSocketDataFromChildNode handler to read and modify user records and camera configuration.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-798

Tecnología: No especificado

Publicado el: 2026-08-29



CVE-2026-82452

Descripción: rust-iot-platform through commit 5df942ab contains an authentication bypass vulnerability where most REST API routes lack authentication guards in their handler signatures.

Unauthenticated attackers can create, update, list, retrieve, and delete user accounts by directly accessing unprotected endpoints without providing valid credentials.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-306

Tecnología: No especificado

Publicado el: 2026-08-29



CVE-2026-82454

Descripción: The Omnivore API (packages/api) before the fix in commit abf53d6 contains an authentication bypass in Apple sign-in token verification. The decodeAppleToken function extracted the 'alg' field from the attacker-supplied JWT header and passed it as the sole allowed algorithm to jwt.verify(). Using jsonwebtoken v8 (which does not validate key/algorithm compatibility), an attacker can set alg=HS256...

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

Tipo: CWE-347

Tecnología: No especificado

Publicado el: 2026-08-29



CVE-2026-82456

Descripción: argocd-mcp 0.8.0 binds its HTTP transport to every network interface and accepts MCP sessions without requiring caller credentials when ARGOCD_API_TOKEN is configured. Attackers who can reach the listener can invoke the full tool surface using the operator's stored token to create applications, request syncs, and modify Argo CD resources.

CVSS: 10.0 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-1327

Tecnología: No especificado

Publicado el: 2026-08-29



Resumen del Reporte

CVEs analizados: 16

Promedio CVSS: 9.75

Fuente: nvd.nist.gov

Nos vemos la próxima semana. Hack the Cat ☹

